



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

Ασφάλεια Δικτύων

Case 6

Επιβλέπον Καθηγητής: Καθ. Χρήστος Ξενάκης

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς
26/11/2025

Περίληψη

Πραγματοποίηση επίθεσης DNS Spoofing με στόχο την υποδομή του DNS server που υλοποιήθηκε στην προηγούμενη άσκηση. Χρησιμοποιώντας το εργαλείο Ettercap στο Kali Linux, επιτεύχθηκε θέση MITM μέσω ARP Poisoning. Στη συνέχεια, μέσω του πρόσθετου `dns_spoof`, η κίνηση του θύματος ανακατευθύνθηκε επιτυχώς σε κακόβουλη ιστοσελίδα που φιλοξενούσε ο Apache server, αντί για τον νόμιμο προορισμό.

Abstract

Execution of a DNS Spoofing attack targeting the DNS server infrastructure implemented in the previous exercise. Using Ettercap on Kali Linux, a MITM position was established via ARP Poisoning. Subsequently, utilizing the `dns_spoof` plugin, the victim's traffic was successfully redirected to a malicious webpage hosted on Apache server, bypassing the legitimate destination.

Περιεχόμενα

Εισαγωγή.....	1
Πρακτικό κομμάτι εργασίας.....	2
Βιβλιογραφία.....	11

Εισαγωγή

Το DNS (Domain Name System) αποτελεί έναν από τους θεμέλιους λίθους της λειτουργίας του διαδικτύου, αναλαμβάνοντας την αντιστοίχιση των ονομάτων των ιστοσελίδων (domain names) σε διευθύνσεις IP. Λόγω της κρισιμότητάς του, αποτελεί συχνό στόχο κυβερνοεπιθέσεων. Μία από τις πιο διαδεδομένες τεχνικές επίθεσης είναι το DNS Spoofing.

Στην παρούσα εργασία θα υλοποιήσουμε μια τέτοια επίθεση και ως βάση θα χρησιμοποιηθεί η υποδομή που αναπτύχθηκε στην προηγούμενη άσκηση (Case 5), όπου εγκαταστάθηκε και παραμετροποιήθηκε ένας νόμιμος DNS server (Ubuntu/BIND9).

Σκοπός της άσκησης είναι η κατανόηση των μηχανισμών επίθεσης MITM. Θα χρησιμοποιήσουμε το λειτουργικό σύστημα Kali Linux και το εργαλείο Ettercap για να εκτελέσουμε ARP Poisoning, παρεμβαλλόμενοι μεταξύ του θύματος (Windows 10) και του DNS server. Στόχος είναι να οδηγήσουμε το θύμα σε μια ελεγχόμενη σελίδα (kalaitzon.gr) που φιλοξενείται στον Apache Web Server του επιτιθέμενου.

Πρακτικό κομμάτι εργασίας

Αρχικά ξεκινάμε με την εύρεση των IP διευθύνσεων με την εντολή `ip a` στα kali linux και ubuntu και `ipconfig` για το windows 10. Είναι οι ίδιες IP από την προηγούμενη άσκηση όπου δημιουργήσαμε DNS Server.

```
skalaizon@ubuntu20.04:~$ sudo systemctl status bind9
[sudo] password for skalaizon:
● named.service - BIND Domain Name Server
   Loaded: loaded (/usr/lib/systemd/system/named.service; enabled; preset: enabled)
   Active: active (running) since Sat 2025-11-22 02:41:16 EET; 3 days ago
     Docs: man:named(8)
    Main PID: 1189 (named)
      Status: "running"
        Tasks: 14 (limit: 9374)
       Memory: 31.0M (peak: 31.8M)
          CPU: 11.296s
      CGroup: /system.slice/named.service
              └─1189 /usr/sbin/named -f -u bind

Nov 23 00:59:06 ubuntu20.04: named[1189]: validating CK0P0JMG874LJREF7EFN8430QVIT8BSM.com/NSEC3: no valid signature found
Nov 23 00:59:06 ubuntu20.04: named[1189]: validating com/SOA: verify failed due to bad signature (keyid=46539): RRSIG validity period has not begun
Nov 23 00:59:06 ubuntu20.04: named[1189]: validating com/SOA: no valid signature found
Nov 23 00:59:06 ubuntu20.04: named[1189]: validating TCQ78V56RPB9M9C06K6FI9U0GRT276QB.com/NSEC3: verify failed due to bad signature (keyid=46539): RRSIG validity period has not begun
Nov 23 00:59:06 ubuntu20.04: named[1189]: validating TCQ78V56RPB9M9C06K6FI9U0GRT276QB.com/NSEC3: no valid signature found
Nov 23 00:59:06 ubuntu20.04: named[1189]: no valid RRSIG resolving 'microsoft.com/DS/IN': 192.55.83.30#53
Nov 23 00:59:06 ubuntu20.04: named[1189]: broken trust chain resolving 'oneocsp.microsoft.com/A/IN': 8.8.8.8#53
Nov 25 10:20:15 ubuntu20.04: named[1189]: _default: sending trust-anchor-telemetry query '_ta-4f66-9728/NULL'
Nov 25 10:20:15 ubuntu20.04: named[1189]: managed-keys-zone: Key 20326 for zone . is now trusted (acceptance timer complete)
Nov 25 10:20:15 ubuntu20.04: named[1189]: managed-keys-zone: Key 38696 for zone . is now trusted (acceptance timer complete)

skalaizon@ubuntu20.04:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: ens32: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:f5:51:1f brd ff:ff:ff:ff:ff:ff
    inet 192.168.137.129/24 brd 192.168.137.255 scope global dynamic noprefixroute ens32
        valid_lft 1276sec preferred_lft 1643sec
    inet6 fe80::20c:29ff:f5:511f/64 scope link
        valid_lft forever preferred_lft forever
skalaizon@ubuntu20.04:~$
```

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:f5:e8:b5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.137.128/24 brd 192.168.137.255 scope global dynamic noprefixroute eth0
        valid_lft 1276sec preferred_lft 1276sec
    inet6 fe80::36ed:f8e6:63b6:348c/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: br-480f97c7b15a: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:38:ae:5a:d1 brd ff:ff:ff:ff:ff:ff
    inet 172.18.0.1/16 brd 172.18.255.255 scope global br-480f97c7b15a
        valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether 02:42:2d:f0:d0:c7 brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$
```

```
C:\> Command Prompt

Microsoft Windows [Version 10.0.19045.6466]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Client_Win10>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : localdomain
    Link-local IPv6 Address . . . . . : fe80::149f:92cd:f6cf:6529%5
    IPv4 Address. . . . . : 192.168.137.130
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.137.2

C:\Users\Client_Win10>
```

Επιτιθέμενος (Kali): 192.168.137.128

DNS Server (Ubuntu): 192.168.137.129

Θύμα (Windows 10): 192.168.137.130

την

```
(kali㉿kali)-[~]
└─$ sudo systemctl start apache2
[sudo] password for kali:

(kali㉿kali)-[~]
└─$ sudo nano /var/www/html/index.html

(kali㉿kali)-[~]
└─$
```

«σερβίρουμε» την επεξεργασμένη σελίδα από εμάς στο θύμα. Η σελίδα θα φέρει μόνο τον τίτλο «YOU HAVE BEEN HACKED». Για αυτό το λόγο χρησιμοποιούμε το apache2. Με την επόμενη εντολή (**sudo nano /var/www/html/index.html**) ανοίγουμε το default root directory όπου το apache ψάχνει να βρει τα αρχεία της ιστοσελίδας. Παρατηρούμε την εξής εικόνα όταν ανοίγουμε το αρχείο:

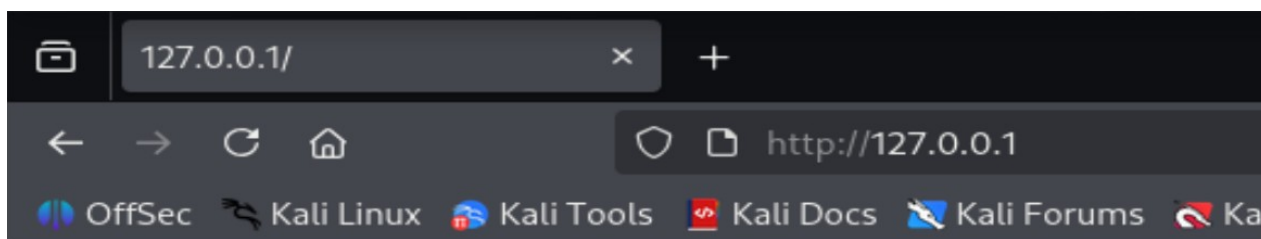
```
kali@kali: ~
Session Actions Edit View Help
GNU nano 8.6 /var/www/html/index.html
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Apache2 Debian Default Page: It works</title>
    <style type="text/css" media="screen">
      * {
        margin: 0px 0px 0px 0px;
        padding: 0px 0px 0px 0px;
      }
      body, html {
        padding: 3px 3px 3px 3px;
        background-color: #D8DBE2;
        font-family: Verdana, sans-serif;
        font-size: 11pt;
        text-align: center;
      }
      div.main_page {
        position: relative;
        display: table;
        width: 800px;
        margin-bottom: 3px;
        margin-left: auto;
        margin-right: auto;
        padding: 0px 0px 0px 0px;
        border-width: 2px;
        border-color: #212738;
        border-style: solid;
        background-color: #FFFFFF;

```

Θα σβήσουμε όλο το περιεχόμενο και θα αφήσουμε μόνο το `<h1> YOU HAVE BEEN HACKED! </h1>`. Δεν είναι αναγκαία διαδικασία αλλά μέσω αυτής δείχνουμε ένα απτό αποτέλεσμα αυτής της επίθεσης.

```
kali@kali: ~
Session Actions Edit View Help
GNU nano 8.6 /var/www/html/index.html *
<h1> YOU HAVE BEEN HACKED! </h1>
```

Το αποθηκεύουμε πατώντας `Ctrl+O` και `Enter` και αποχωρούμε από το έγγραφο πατώντας `Ctrl+X`. Για να ελέγξουμε ότι η σελίδα δουλεύει θα πληκτρολογήσουμε στον browser μας την IP `127.0.0.1`. Η διεύθυνση αυτή είναι η πιο διάσημη IP και είναι ουσιαστικά ο `localhost`. Για να ελέγξουμε αν το `apache` που μόλις στήσαμε στον επιτιθέμενο, δουλεύει σωστά, τρέξαμε την ιστοσελίδα στον ίδιο `host`, χωρίς να βγούμε στο δίκτυο. Παρατηρούμε ότι η ιστοσελίδα είναι λειτουργική και μένει να προχωρήσουμε στο επόμενο κομμάτι: `Ettercap`



YOU HAVE BEEN HACKED!

Με την εντολή **sudo nano /etc/ettercap/etter.dns** ανοίγουμε το configuration file του dns_spoof, του εργαλείου Ettercap. Με άλλα λόγια το etter.dns περιλαμβάνει τα domains που θέλουμε να «χαλάσουμε» και να στείλουμε στο θύμα μας.



Αφού ανοίξουμε το αρχείο, θα γράψουμε τα εξής, υποχρεωτικά αλλά και προαιρετικά:

- **kalaitzon.gr**: Αυτή η γραμμή πιάνει την περίπτωση που κάποιος γράψει σκέτο το όνομα, χωρίς τίποτα μπροστά
- ***.kalaitzon.gr**: Σημαίνει «οτιδήποτε» πριν από το kalaitzon.gr. Π.χ. αν ο χρήστης γράψει mail.kalaitzon.gr, admin.kalaitzon.gr ή οτιδήποτε άλλο
- **www.kalaitzon.gr**: Είναι η κλασική περίπτωση που γράφουμε www. Κανονικά το καλύπτει η προηγούμενη περίπτωση αλλά για σιγουριά το δηλώνουμε ξεχωριστά

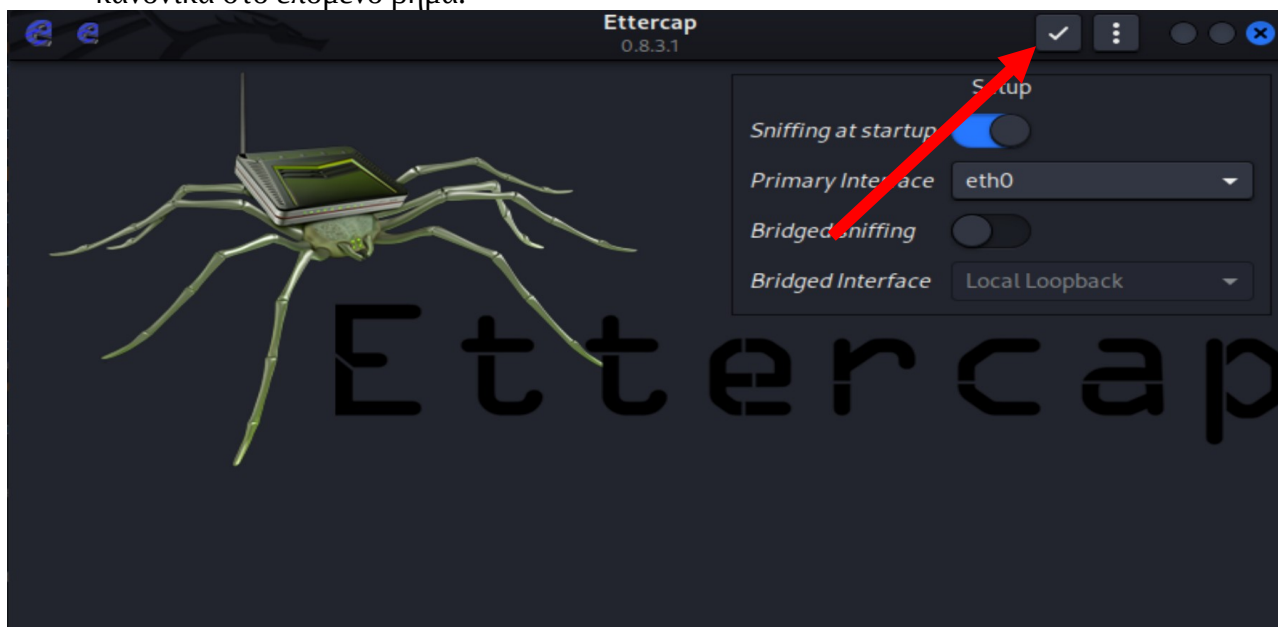
```
# or for TXT query (value must be wrapped in double quotes):  
# google.com TXT "v=spf1 ip4:192.168.0.3/32 ~all" [TTL]  
  
kalaitzon.gr      A      192.168.137.128  
*.kalaitzon.gr   A      192.168.137.128  
www.kalaitzon.gr A      192.168.137.128  
  
NOTE: the wilddcarded hosts can't be used to poison the PTR requests  
# so if you want to reverse poison you have to specify a plain  
# host. (look at the www.microsoft.com example)
```

Με αυτό τον τρόπο λέμε ότι αν κάποιος άλλος χρήστης ρωτήσει στο δίκτυο για την ιστοσελίδα kalaitzon.gr για παράδειγμα, τότε αντί να την ανατροφοδοτήσουμε στην IP του Ubuntu ως DNS server, την ανατροφοδοτούμε στην IP του επιτιθέμενου

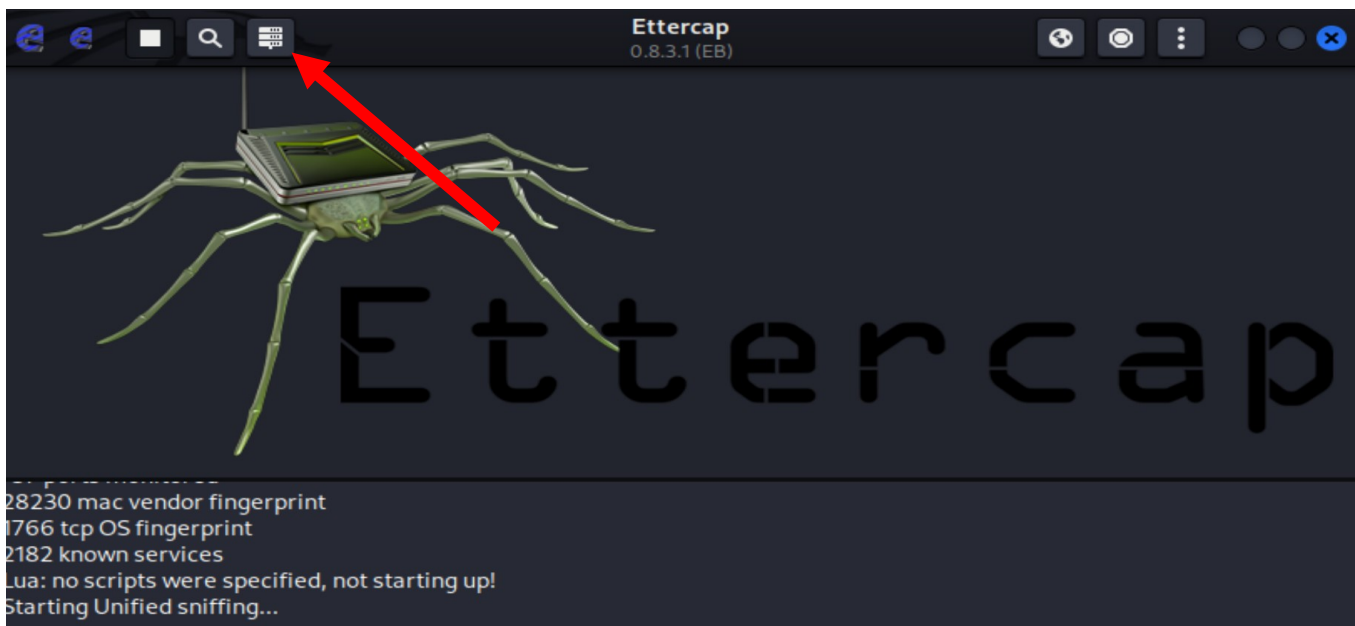
(kali linux) χωρίς να το γνωρίζει το θύμα μέχρι να δει φυσικά το μήνυμα στην οθόνη του («YOU HAVE BEEN HACKED!»).

```
(kali@kali)-[~]  
$ sudo ettercap -G  
ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team
```

Τέλος δίνουμε δικαιώματα διαχειριστή (root) για να παρακολουθήσουμε το δίκτυο ως MITM με το εργαλείο Ettercap. Επιπλέον με το -G ανοίγουμε ένα γραφικό interface για να τρέξουμε τις απαραίτητες ενέργειες με αυτό τον τρόπο αντί να τις γράφουμε. Σε ξεχωριστό παράθυρο λοιπόν παρατηρούμε ότι η διεπαφή του δικτύου είναι σωστά ρυθμισμένη στην κάρτα δικτύου του kali linux και για αυτό προχωράμε κανονικά στο επόμενο βήμα.

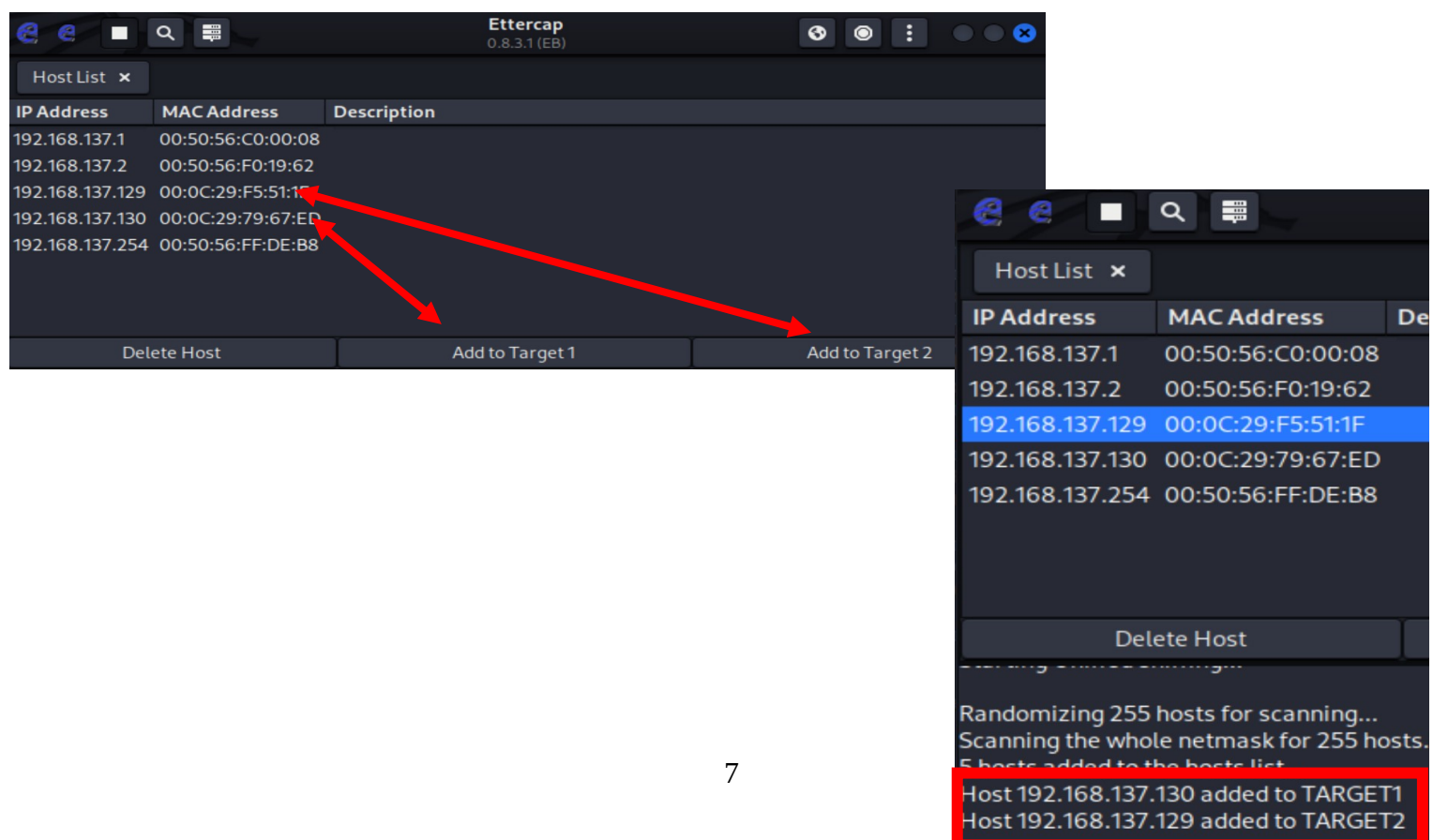


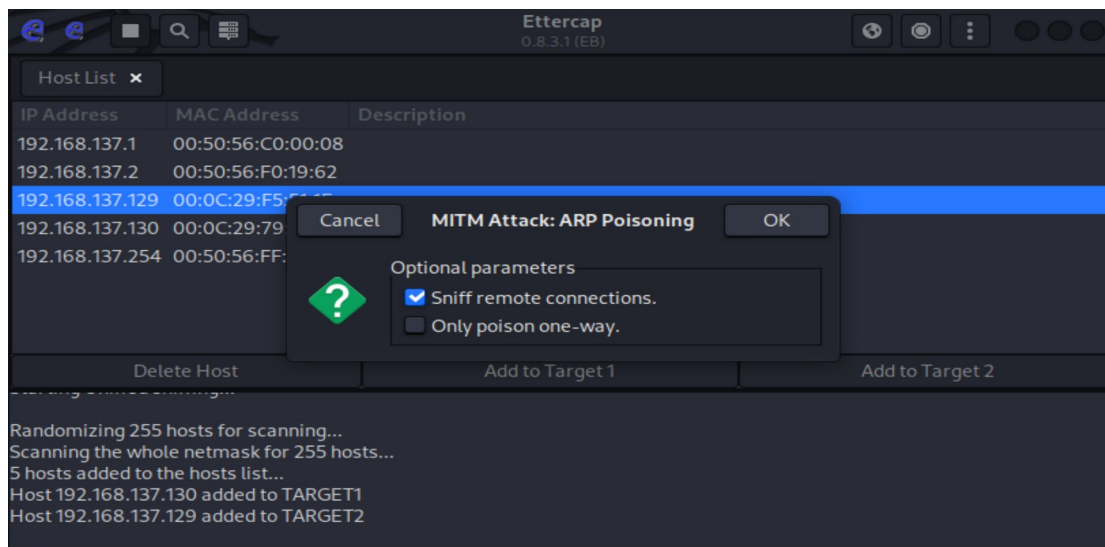
Με την επιλογή που υποδεικνύει το βελάκι, το Ettercap έδωσε εντολή στην κάρτα δικτύου (eth0) να μπει σε Promiscuous Mode. Δηλαδή από εκεί που η κάρτα δικτύου διάβαζε μόνο τα πακέτα που προορίζονταν για το συγκεκριμένο host (kali linux), τώρα διαβάζει ό,τι κινείται. Με άλλα λόγια παρακολουθεί την κίνηση του δικτύου.



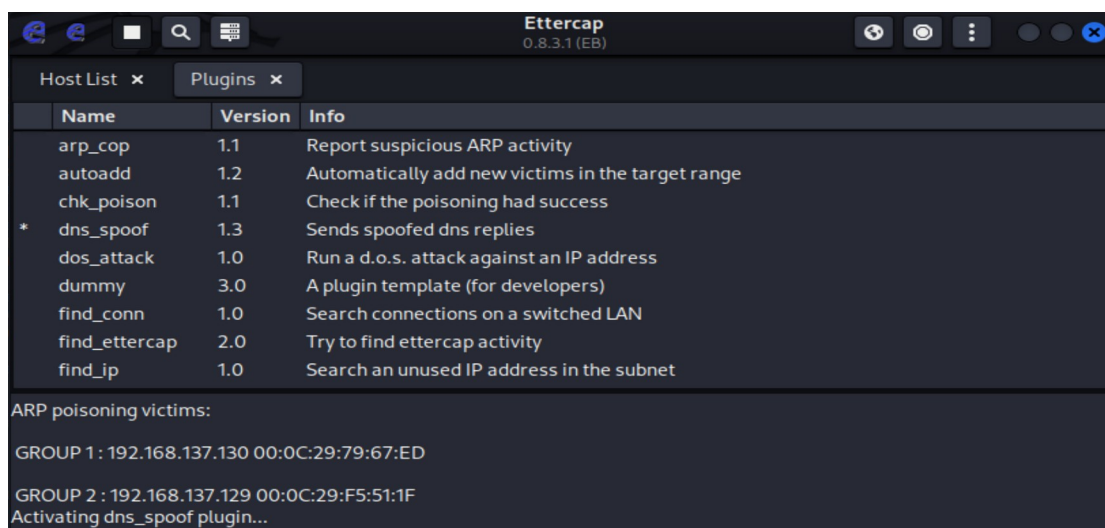
Επιλέγοντας το συγκεκριμένο εικονίδιο βλέπουμε ότι η διαδικασία του scanning ολοκληρώθηκε και εμφανίζει όλους hosts που εντόπισε το Ettercap στο δίκτυο. Βλέπουμε την IP και του θύματος αλλά και του DNS server.

Θα επιλέξουμε τους στόχους μας και συγκεκριμένα το Windows 10 ως τον target1 και το Ubuntu DNS server ως τον target2, όπως φαίνεται στην παρακάτω εικόνα.





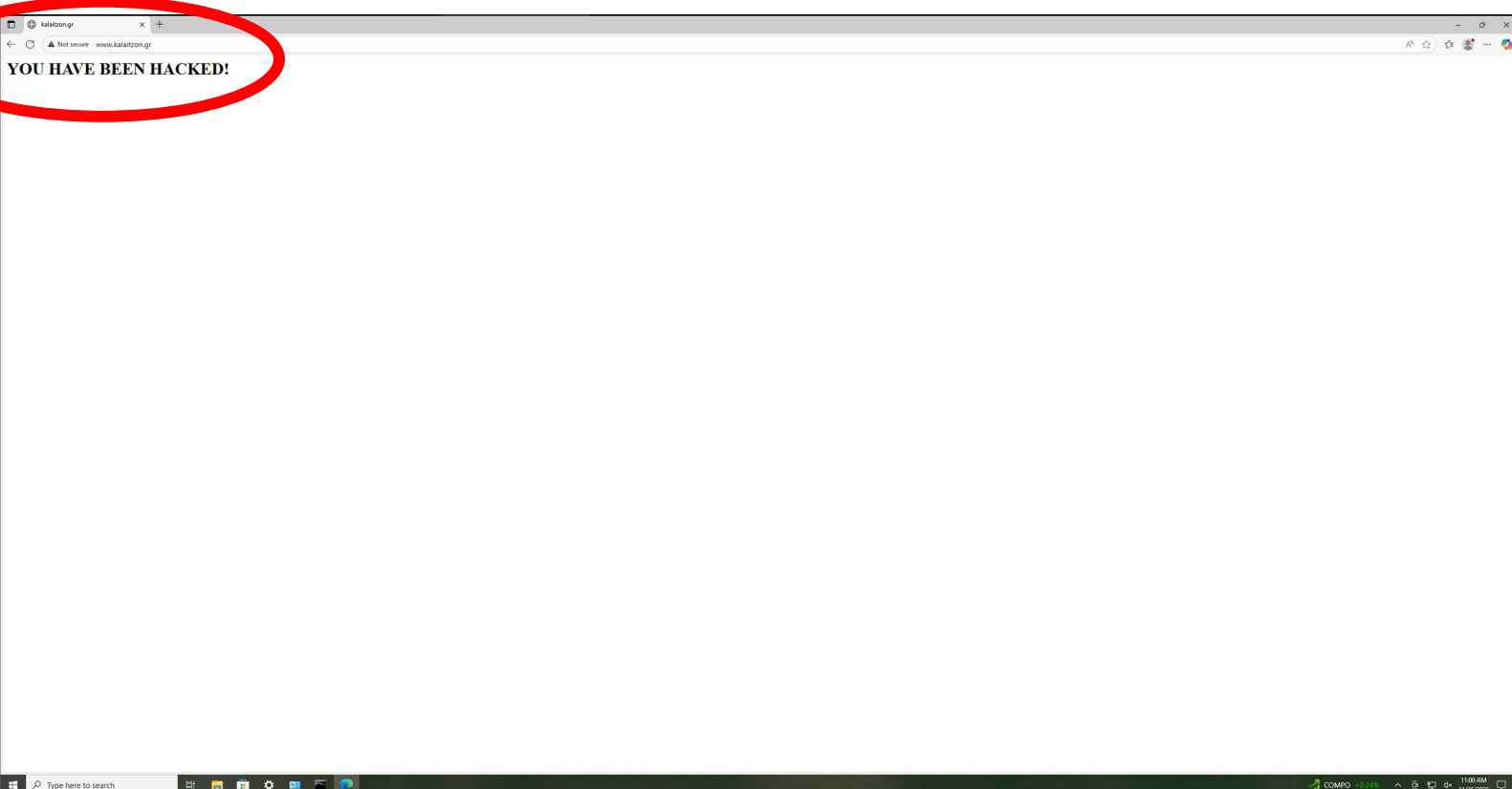
Επιλέγοντας το εικονίδιο με την υδρόγειο και ενεργοποιώντας το ARP Poisoning, αλλάζουμε τη ροή της πληροφορίας στο δίκτυο. Συγκεκριμένα, πριν την επίθεση, η επικοινωνία ήταν άμεση. Δηλαδή το θύμα (Windows 10) έστελνε τα αιτήματα DNS απευθείας στον DNS server (Ubuntu). Τώρα, με το ARP Poisoning, παρεμβαλλόμαστε ως MITM. Το εργαλείο πείθει το θύμα ότι εμείς είμαστε ο server.



Στη συνέχεια, για την ολοκλήρωση της επίθεσης, ενεργοποιούμε το πρόσθετο (plugin) dns_spoof. Η ενεργοποίησή του επιβεβαιώνεται από την εμφάνιση του αστερίσκου (*) στα αριστερά του ονόματός του. Ενώ με το ARP Poisoning επιτυγχάναμε απλώς την παρακολούθηση της κίνησης (Sniffing), πλέον με το dns_spoof το Kali Linux συμμετέχει ενεργά στη διαδικασία. Συγκεκριμένα, το εργαλείο παρακολουθεί τη ροή των πακέτων και μόλις εντοπίσει αίτημα DNS που αφορά το domain kalaitzon.gr, παρεμβαίνει άμεσα. Αντί να επιτρέψει την απάντηση

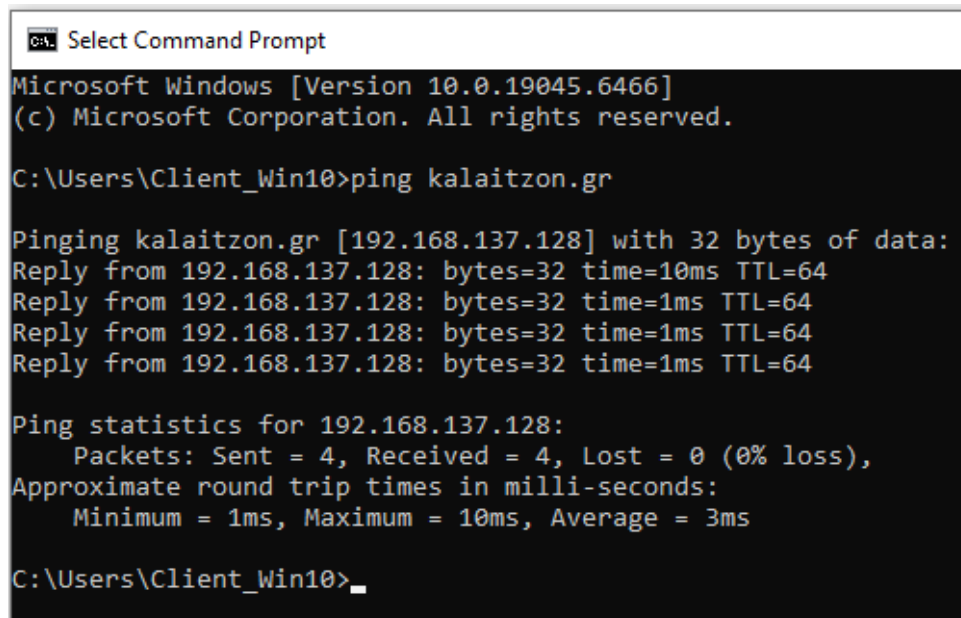
από τον νόμιμο server, αποστέλλει στο θύμα μια πλαστή απάντηση (spoofed reply) με την IP του επιτιθέμενου (.128), ανακατευθύνοντας έτσι την κίνηση.

Τέλος, για την επαλήθευση της επίθεσης, μεταβαίνουμε στον υπολογιστή του θύματος (Windows 10) και ανοίγουμε τον browser. Πληκτρολογώντας τη διεύθυνση www.kalaitzon.gr, παρατηρούμε ότι εμφανίζεται η σελίδα με το μήνυμα «YOU HAVE BEEN HACKED!». Το γεγονός αυτό επιβεβαιώνει ότι η επίθεση DNS Spoofing λειτούργησε. Συγκεκριμένα, όταν το θύμα αναζήτησε το domain, ο επιτιθέμενος (Kali Linux) παρενέβη στη διαδικασία. Μέσω του Ettercap, απέστειλε μια πλαστή απάντηση (spoofed response) πριν προλάβει να απαντήσει ο νόμιμος DNS server. Ως αποτέλεσμα, ο browser του θύματος δρομολογήθηκε λανθασμένα στην IP του επιτιθέμενου (.128), φορτώνοντας την κακόβουλη ιστοσελίδα που φιλοξενείται στον Apache Web Server του Kali, αντί για το πραγματικό περιεχόμενο.



Επιπρόσθετα, για την επιβεβαίωση της επίθεσης σε επίπεδο δικτύου, εκτελέστηκε η εντολή **ping kalaitzon.gr** στη γραμμή εντολών (CMD) του θύματος. Όπως φαίνεται στην εικόνα, το σύστημα επιλύει το όνομα τομέα στην IP διεύθυνση

192.168.137.128, η οποία αντιστοιχεί στο μηχάνημα του επιτιθέμενου (Kali Linux). Αν η επίθεση είχε αποτύχει, η εντολή θα επέστρεφε την IP 192.168.137.129 του νόμιμου DNS Server. Το αποτέλεσμα αυτό αποδεικνύει ότι η διαδικασία DNS Spoofing ήταν επιτυχής, καθώς το θύμα δρομολογείται λανθασμένα στον κακόβουλο κόμβο.



```
C:\> Select Command Prompt

Microsoft Windows [Version 10.0.19045.6466]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Client_Win10>ping kalaitzon.gr

Pinging kalaitzon.gr [192.168.137.128] with 32 bytes of data:
Reply from 192.168.137.128: bytes=32 time=10ms TTL=64
Reply from 192.168.137.128: bytes=32 time=1ms TTL=64
Reply from 192.168.137.128: bytes=32 time=1ms TTL=64
Reply from 192.168.137.128: bytes=32 time=1ms TTL=64

Ping statistics for 192.168.137.128:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 1ms, Maximum = 10ms, Average = 3ms

C:\Users\Client_Win10>_
```

Βιβλιογραφία

Udacity. (2015, February 23). *Apache Web Server* [Video file]. Retrieved from <https://www.youtube.com/watch?v=2lCR0FGLn2c>

Flavor Of The Month. (2020, November 2). *Install & set up Apache Web Server on Windows 10 - quickly!* [Video file]. Retrieved from <https://www.youtube.com/watch?v=oJnCEqeAsUk>

Loi Liang Yang. (2019, December 14). *Get Usernames and Passwords with Ettercap, ARP Poisoning (Cybersecurity)* [Video file]. Retrieved from <https://www.youtube.com/watch?v=CW0Mf9qGBOc>

NetworkChuck. (2020, November 16). *how Hackers SNIFF (capture) network traffic // MiTM attack* [Video file]. Retrieved from <https://www.youtube.com/watch?v=-rSqbgl7oZM>

Chris Greer. (2021, December 9). *How ARP poisoning works // Man-in-the-Middle* [Video file]. Retrieved from <https://www.youtube.com/watch?v=cVTUeEoJgEg>

HackerSploit. (2018, February 15). *MITM With Ettercap - ARP Poisoning* [Video file]. Retrieved from <https://www.youtube.com/watch?v=3UD738uE7Tg>

The Linux Point. (2021, April 16). *Kali Linux - Man in the Middle Attack (MITM) tutorial using Ettercap* [Video file]. Retrieved from <https://www.youtube.com/watch?v=LEPEk5pFffw>

Google Gemini. (n.d.). Retrieved from <https://gemini.google.com/app>